

Lab 2: Verifying Your Toolset — Reconnaissance and a First Scan

Session 2 — Tool Familiarization & Baseline Tasks

Estimated time: 90 minutes **Prerequisite:** Lab 1 completed — Kali, Metasploitable 2, and OWASP BWA are running, mutually reachable on your host-only network, and you've confirmed isolation from the Internet. **Based on:** Module 1's reconnaissance, scanning, and interception walkthroughs

1. Learning Objectives

By the end of this session you will be able to:

- Run passive reconnaissance tools (`whois`, `dig`, `theHarvester`) without touching a live target
- Run an active Nmap scan against a target you're authorized to test, and read its OPEN / CLOSED / FILTERED verdicts
- Capture and read unencrypted credentials in transit with Wireshark
- Explain why each action is legal inside this lab, and would not be legal against a network you don't own

2. ⚠ Scope Reminder

Everything in this lab stays inside your host-only network (from Lab 1) plus `example.com` — a domain the standards bodies reserve specifically for use in demonstrations like this one. **Do not** point any tool in this lab at a live IP address, domain, or Wi-Fi network you don't own or haven't been given written authorization to test. That distinction — documented permission — is the subject of the entire module this lab supports.

3. Tools Used This Session

All pre-installed on Kali: `whois`, `dig` / `host`, `theHarvester`, `nmap`, `wireshark`, a browser.

4. Procedure

Part A — Passive Reconnaissance (No Packets to a Real Target)

Passive recon pulls from public registries and search engines — none of it touches the target directly.

1. WHOIS lookup:

```
whois example.com
```

Record: registrar, registration/expiry dates, name servers.

2. DNS enumeration:

```
dig example.com ANY
host -a example.com
```

Record: A records, and MX records if any.

3. theHarvester — scrape the open web for subdomains and email patterns:

```
theHarvester -d example.com -b google
```

Record: number of hosts/subdomains found.

Reflection (2-3 sentences): Which of these three commands, if any, would appear in `example.com`'s server logs? Why does that matter for how testers sequence their work?

Part B — Active Scanning (Your Own Lab Target Only)

Switch to your authorized target: your own Metasploitable 2 VM.

1. Confirm its IP address from Lab 1 (e.g., `192.168.56.102`).

2. Run a version and OS-detection scan:

```
nmap -sV -O 192.168.56.102
```

3. For at least **five** open ports, record:

- Port number and protocol
- Service name and version string
- State: open, closed, or filtered

4. One service on this box has a version string that is itself a known vulnerability — it’s an FTP server, and the exact version number is the finding. Search the version string plus “backdoor” and write one sentence on what you find. **Do not attempt to exploit it this session** — exploitation is covered once you’ve been authorized to do so in a later module.

Part C — Watching Traffic in the Clear (Wireshark)

1. Open Wireshark on Kali and start a capture on your host-only interface (e.g., `eth0` — the one on the host-only subnet, not any NAT/bridged interface).
2. From a terminal, connect to Metasploitable’s FTP service and attempt a login with the credentials your instructor provided:

```
ftp 192.168.56.102
```

3. Stop the capture and filter on:

```
ftp
```

4. Locate the `PASS` command in the packet list and open it. Record what the payload shows.

Reflection (2-3 sentences): Packet capture is covered by a different statute than the one covering unauthorized access. Why might a scope document that authorizes scanning need to say something separately about capturing traffic?

Part D — Confirm OWASP BWA Is Reachable

1. From a browser on Kali, browse to your OWASP BWA VM’s IP address.
2. Confirm the landing page listing the vulnerable applications loads.
3. No further interaction is required this session — later modules use this target directly.

5. What to Submit

A one-page lab report containing:

1. Your WHOIS/`dig`/theHarvester findings for `example.com`
2. Your Nmap results table (port, service, version, state) for at least 5 ports on Metasploitable
3. One sentence identifying the vulnerable service and version you found
4. A screenshot of the captured FTP exchange in Wireshark, with the credential value **redacted** in your writeup
5. Answers to both reflection questions

6. Troubleshooting

Symptom	Likely cause / fix
<code>theHarvester</code> returns nothing	The <code>-b google</code> backend may be rate-limited; try <code>-b duckduckgo</code> or <code>-b bing</code>
Nmap shows all ports filtered	Confirm you’re scanning the current host-only address — re-check with <code>ifconfig</code> on Metasploitable, it may have changed
No <code>PASS</code> packet appears in Wireshark	Confirm the capture interface matches your host-only adapter — Wireshark will silently capture the wrong interface without warning

This closes out the Module 1 lab pair. Module 2 moves from what you may do to how networks actually carry the traffic you’ve just started testing — bring your lab VMs to the next session.

